

Clase 280 — Controles CIS

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: *CIS Critical Security Controls v8.1 (Center for Internet Security)* ⌚ Duración estimada: **90 min** · Nivel: **Intermedio**

Objetivo

Aprender a usar los CIS Critical Security Controls v8.1, un conjunto priorizado y accionable de 18 controles y 153 salvaguardas que responde a la pregunta "¿por dónde empiezo?". Al terminar sabrás priorizar defensas con los Implementation Groups (IG1–IG3), aplicar los CIS Benchmarks para endurecer sistemas y usar los controles como plan de acción técnico concreto, complementario a CSF e ISO.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Describir** la estructura de los 18 controles CIS v8.1 y sus salvaguardas.
2. **Seleccionar** el Implementation Group (IG1/IG2/IG3) adecuado a una organización.
3. **Priorizar** las salvaguardas de "higiene cibernética esencial" (IG1).
4. **Aplicar** un CIS Benchmark para endurecer un sistema concreto.
5. **Mapear** los controles CIS a NIST CSF e ISO 27001.

Temas

#	Tema	Por qué importa
1	Origen y filosofía de los CIS Controls	Priorización basada en ataques reales
2	Los 18 controles v8.1	Cobertura de inventario a pruebas de intrusión
3	Salvaguardas (Safeguards)	Unidad accionable y medible
4	Implementation Groups IG1–IG3	Escalar según recursos y riesgo
5	Higiene cibernética esencial (IG1)	El mínimo defendible
6	CIS Benchmarks	Endurecimiento concreto de sistemas
7	Mapeos a CSF, ISO, PCI	Reutilizar el esfuerzo

Definiciones y características

- **CIS Controls:** conjunto priorizado de acciones defensivas contra los ataques más comunes. *Clave:* ordenados por impacto, no alfabéticamente.
- **Salvaguarda (Safeguard):** acción concreta y medible dentro de un control. *Clave:* v8.1 tiene 153 salvaguardas.
- **IG1 (Implementation Group 1):** higiene esencial para organizaciones pequeñas con recursos limitados. *Clave:* 56 salvaguardas base defendibles.

- **IG2:** para organizaciones con equipos dedicados de seguridad. *Clave:* incluye IG1 más controles avanzados.
- **IG3:** para entornos maduros con datos muy sensibles. *Clave:* las 153 salvaguardas.
- **CIS Benchmark:** guía de configuración segura para un producto concreto (Windows, Linux, AWS, etc.). *Clave:* endurecimiento reproducible y auditable.
- **CIS-CAT:** herramienta que evalúa el cumplimiento de un sistema frente a un Benchmark. *Clave:* automatiza la evidencia.

Herramientas y preparación

- El documento *CIS Controls v8.1* (descarga gratuita tras registro en [cisecurity.org](https://www.cisecurity.org)).
- Un *CIS Benchmark* del sistema que quieras endurecer (Ubuntu, Windows 11, Docker, etc.).
- Opcional: *CIS-CAT Lite* (versión gratuita) o herramientas open source como **Lynis** (`sudo apt install lynis`) para auditar Linux.
- Una VM aislada de laboratorio para aplicar el endurecimiento (Ubuntu Server recomendado).
- Hoja de cálculo para el plan de salvaguardas IG1.

 El endurecimiento se practica en una VM de laboratorio propia. No modifiques sistemas de producción ni ajenos sin autorización.

Laboratorio guiado (ejercicio aplicado)

Parte A — Plan de salvaguardas IG1 para "Ferretería del Sur S.A.":

1. **Descarga** los CIS Controls v8.1 y filtra las salvaguardas marcadas como IG1.
2. **Inventario** (Control 1 y 2): lista cómo mantendrías el inventario de activos y software; anota la herramienta que usarías.
3. **Selecciona 15 salvaguardas IG1** prioritarias (gestión de cuentas, MFA, configuración segura, copias de seguridad, formación) y ponlas en una hoja con: control, salvaguarda, estado actual, acción, responsable.

Parte B — Endurecimiento con un Benchmark (VM Ubuntu):

4. En tu VM aislada, ejecuta una auditoría base:

```
sudo apt update && sudo apt install -y lynis
sudo lynis audit system
```

5. Anota el "Hardening index" inicial y 5 sugerencias de Lynis.
6. Aplica 3 medidas concretas del CIS Benchmark de Ubuntu (p. ej. deshabilitar servicios innecesarios, configurar `auditd`, endurecer `sshd_config` con `PermitRootLogin no`).
7. Re-ejecuta `lynis audit system` y compara el índice antes/después.
8. **Mapeo:** para 5 de tus salvaguardas, anota el equivalente en NIST CSF y en ISO 27001 Anexo A usando la tabla de mapeos de CIS.

Ejercicios

1. Ordena estos controles CIS por su número y explica por qué el inventario va primero.
2. Una PYME sin equipo de seguridad: ¿qué IG le corresponde y por qué?
3. Elige 5 salvaguardas IG1 y clasifícalas en preventivas o detectivas.
4. Explica qué es un CIS Benchmark y da un ejemplo de regla de endurecimiento SSH.
5. Mapea el control "MFA en accesos remotos" a CSF, ISO 27001 y PCI-DSS.
6. Propón cómo medirías el porcentaje de salvaguardas IG1 implementadas.

Reto verificable

Entrega un **plan de higiene cibernética IG1** con al menos 20 salvaguardas priorizadas (estado, acción, responsable) y evidencia de un endurecimiento real en VM (índice de Lynis antes/después de aplicar 3 medidas de un CIS Benchmark).

Criterio de aceptación: el plan cubre al menos 8 de los 18 controles, el índice de Lynis mejora tras el endurecimiento, y 5 salvaguardas están mapeadas a CSF/ISO.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Intentar implantar los 18 controles a la vez	Sobrecarga; empieza por IG1 y escala
Saltarse el inventario (Controles 1–2)	Todo lo demás depende de conocer los activos; empieza ahí
Aplicar un Benchmark en producción sin probar	Puede romper servicios; prueba primero en VM
Confundir CIS Controls con CIS Benchmarks	Controles = qué hacer; Benchmarks = cómo configurar un producto
No medir el progreso	Define % de salvaguardas implementadas como KPI

Preguntas frecuentes

? ¿CIS reemplaza a NIST CSF o ISO 27001? No. CIS es el "cómo" técnico y priorizado; CSF/ISO son los marcos de gestión. CIS publica mapeos oficiales entre ellos.

? ¿Por dónde empiezo con recursos mínimos? Por IG1: inventario de activos y software, gestión de cuentas, MFA, configuración segura y copias de seguridad. Es la higiene esencial defendible.

? ¿Los CIS Benchmarks son gratis? Los PDF sí, tras registro. Herramientas como CIS-CAT Pro requieren membresía; CIS-CAT Lite y Lynis cubren lo básico.

? ¿Cada cuánto se actualizan? Los Controles se revisan cada pocos años (v8 en 2021, v8.1 en 2024); los Benchmarks se actualizan con cada versión de producto.

Referencias

- CIS Critical Security Controls v8.1. <https://www.cisecurity.org/controls/v8-1>

- CIS Benchmarks. <https://www.cisecurity.org/cis-benchmarks>
- CIS Controls Navigator (mapeos). <https://www.cisecurity.org/controls/cis-controls-navigator>
- Lynis (auditoría de sistemas). <https://cisofy.com/lynis/>
- (ISC)² CISSP Official Study Guide, dominio 1.

Siguiente clase

Clase 281 - Cumplimiento: GDPR, HIPAA y PCI-DSS